

Full length article

Towards an integrated security decision-making framework

Manny Niri¹

School of Engineering, Computing, and Mathematics, Oxford Brookes University, Oxford, UK

ARTICLE INFO

Keywords:

Security decision-making
Attack graphs
Crime scripting
Risk assessment
Requirements engineering
Identity theft
Uncertainty

ABSTRACT

Security decision-making in socio-technical systems can often be limited by fragmented analytical approaches that may struggle to address the complexities of modern threats. This article proposes an integrated multidisciplinary framework that synthesises five key pillars: Goal-Oriented Requirements Engineering (GORE), Risk Assessment (RA), Crime Scripting (CSA), Quantitative Decision Analysis (QDA), and Attack-Graph Modelling (AGM). By incorporating attack graphs as a fifth layer, the framework seeks to provide a *dual-view* of the adversary, bridging the gap between human procedural behaviour (the script) and technical exploit dependencies (the graph). This integrated approach is designed to assist decision-makers in systematically identifying stakeholder goals, characterising multi-path attack trajectories, and evaluating resolution actions using explicit uncertainty ranges. The framework generates a *Unified Conceptual Model*—a visual, auditable artefact intended to reveal underlying trade-offs between security, usability, and profitability. Illustrated through a demonstrative case study, this research offers practitioners a structured decision-support model with potential applicability to finance, critical infrastructure, and cloud environments.

1. Introduction

Security decision-making is a critical, multi-dimensional, and inherently complex activity that can serve as a primary safeguard for protecting valuable assets within modern socio-technical systems. At its core, this process involves the systematic identification of multifaceted security risks and the subsequent selection of effective resolution actions—alternatively conceptualised as countermeasures, security controls, or mitigations. The objective is not just to reduce risk in isolation but to do so while navigating a web of often conflicting stakeholder goals. For instance, requiring in-branch identity verification before activating a new credit card may reduce fraud but degrade customer onboarding speed—a tension this article examines directly through a worked case study in Section 4. These decisions are not isolated events confined to a single development phase; rather, they recur iteratively throughout the entire system lifecycle. This spans from the early stages of requirements elicitation and high-level architectural design, through the complex steps of implementation and deployment, to the long-term demands of ongoing operations and continuous maintenance. In every phase, decision-makers are tasked with evaluating an array of alternatives, each presenting unique trade-offs regarding financial expenditure, system usability, operational performance, regulatory compliance, and residual risk exposure. While the notion of *perfect security* is widely understood to be an unachievable ideal, the actual quality and long-term efficacy of security outcomes are arguably governed less by the deployment of any single technological “silver

bullet” and more by the analytical depth, transparency, and rigour of the underlying decision-making processes.

The stakes associated with these decisions are high. The rapid and widespread digitalisation of global services — fuelled by the convergence of cloud-native computing, mobile-first technologies, the Internet of Things (IoT), and the recent explosion of generative Artificial Intelligence — has expanded the *attack surface* available to sophisticated malicious actors. Among these threats, identity theft remains one of the more persistent and economically devastating forms of financial crime. According to the *Cifas Fraudscape 2026* report, the United Kingdom recorded a notable 444,993 fraud cases in 2025 alone, representing a 6% year-on-year increase. Of these, over 242,000 incidents were classified as identity fraud, which now accounts for 54% of all fraud-risk cases reported to the National Fraud Database (Cifas, 2026).

In the field of requirements engineering, goal-oriented approaches such as KAOS, *i**, and Tropos have been extensively modified to model security requirements, allowing analysts to capture complex stakeholder trade-offs and evaluate competing design configurations (Horkoff et al., 2019). These have been strengthened by complementary techniques such as the Cost-Benefit Analysis Method (CBAM) (Moore et al., 2003) and various uncertainty-aware reasoning frameworks (Letier et al., 2014), which facilitate a more systematic quantification of the benefits, costs, and risks associated with specific architectural strategies. Further research has explored the specific details of security trade-off analysis (Haley et al., 2008), obstacle analysis (Letier and

E-mail address: mniri@brookes.ac.uk.<https://doi.org/10.1016/j.cose.2026.105172>

Received 27 May 2026; Received in revised form 18 August 2026; Accepted 14 September 2026

Available online 24 September 2026

0167-4048/© 2026 The Author. Published by Elsevier Ltd. This is an open access article under the CC BY license (<http://creativecommons.org/licenses/by/4.0/>).

Van Lamsweerde, 2025), and the complex integration of security objectives with non-functional requirements like system availability and performance. Simultaneously, the field of crime science has advanced the use of crime script analysis (Dehghanniri and Borrión, 2021) as a structured methodology for deconstructing the “crime commission process” into a sequence of discrete scenes and specific offender actions. Recent empirical applications have demonstrated the flexibility of crime scripts in modelling cyber-enabled crime, including the systematic theft of data from organisational networks (Madarie et al., 2025), the procurement of counterfeit identity documents (Holt and Lee, 2022), and the execution of card-not-present fraud in e-commerce environments (Bødker et al., 2023; Dehghanniri and Borrión, 2021).

Furthermore, risk assessment methodologies have provided practitioners with robust visual and analytical tools, notably bow-tie diagrams for consequence analysis (Aven, 2008) and sophisticated probabilistic models that move beyond simplistic point estimates to quantify uncertainty more realistically (Kaplan and Garrick, 1981; Aven, 2008). Quantitative decision analysis techniques have further emphasised the necessity of representing uncertainty explicitly — utilising tools such as interval arithmetic, sensitivity analysis, and Bayesian belief networks — to avoid the pitfalls of deterministic or purely subjective qualitative judgements (Marchau et al., 2019). However, each approach has important limitations when used in isolation. Goal-oriented requirements engineering approaches effectively capture modelling the *what* and *why* of stakeholder objectives but often treat the *how* of the attacker’s procedural behaviour as an abstraction. Conversely, crime script analysis provides granular, step-by-step insight into the offender’s journey but is rarely linked quantitatively to high-level organisational goals or formal decision-support models. Risk assessment techniques offer structured consequence modelling but frequently lack the procedural detail required for targeted intervention design. Finally, while quantitative methods offer mathematical rigour, they frequently model the adversary as a static system rather than a dynamic decision-driven agent capable of adapting to new controls. This highlights the utility of an integrated mechanism that can simultaneously reveal: (i) the degree to which a single control satisfies or undermines conflicting stakeholder security and non-security goals; (ii) which specific procedural steps within an attacker’s crime script are effectively obstructed; (iii) how the intervention shifts the attacker’s own decision calculus regarding effort and success probability; and (iv) the resulting overall risk magnitude when viewed through the lens of realistic uncertainty ranges.

To address these limitations, the present article proposes a multidisciplinary modelling language and an integrated decision-support framework. Our approach builds upon and extends a previous synthesis of four foundational fields (Dehghanniri et al., 2015) — goal-oriented requirements engineering, crime science (specifically the “11 Ds” of Situational Crime Prevention), risk assessment, and quantitative decision analysis — by exploring the integration of attack-graph techniques as a critical fifth layer. While crime scripts capture the human and procedural elements of an attack, attack graphs (and their probabilistic variants) model the systemic vulnerabilities, exploit dependencies, and multi-path trajectories inherent in complex, cloud-native, and cyber-physical environments (Wang et al., 2008). This integration allows for a *dual-view* of the adversary: one that is procedural and behavioural (the script) and one that is systemic and technical (the graph). A worked comparison demonstrating this dual-view for the identity-theft case is presented in Section 4.2 (Table 7).

The resulting framework is designed to support decision-makers in systematically: (a) identifying a set of stakeholders and their associated security goals; (b) characterising potential attacks through a hybrid approach of crime scripts and attack graphs; (c) quantifying the expected value of potential resolution actions while explicitly accounting for uncertainty via range-based estimates; and (d) mapping each resolution action to specific script steps and attack paths to demonstrate exactly where the adversary is stopped. The *Unified Conceptual Model* generated by the framework provides a visual *common operating*

picture, allowing stakeholders to compare alternatives with enhanced transparency, identify hidden side-effects on usability or profitability, and ultimately select interventions that offer better value under the pressures of real-world uncertainty.

This trade-off between security rigour and operational efficiency is examined in detail through a realistic identity-theft case study involving credit-card application fraud—a scenario specifically chosen for its ongoing relevance to the global financial landscape (Cifas, 2026).

Beyond the framework itself, this article makes the following contributions: (i) a formal specification of the model as a tuple with explicit mapping functions linking resolution actions to crime-script scenes, attack-graph edges, and stakeholder goals (Section 3.1); (ii) an algorithmic procedure operationalising this specification into a reproducible ranking process (Section 3.2); (iii) a comparison method demonstrating the specific analytical capabilities *attack-graph modelling* adds beyond the four-pillar predecessor of Dehghanniri et al. (2015) (Sections 2.5 and 2.6); (iv) a set of proposed evaluation criteria to support future empirical validation (Section 3.6); and (v) a demonstrative case-study application illustrating the framework’s mechanics (Section 4).

2. Background

Security decision-making under uncertainty spans several distinct academic disciplines, each contributing partial solutions to the challenges outlined above. As systems become increasingly interconnected and autonomous, the complexity of protecting them grows considerably. Individual disciplines frequently focus on specific sub-domains, which can create challenges when attempting to simultaneously address the diverse range of requirements: from abstract stakeholder goals and attacker behaviour to the granular mechanics of crime processes, systemic exploit pathways, and quantitative trade-offs. This section provides a critical review of the five foundational pillars that underpin the enhanced framework presented in this paper: goal-oriented requirements engineering, formal risk assessment, crime scripting (drawn from environmental criminology), quantitative decision analysis under deep uncertainty, and attack-graph modelling—the last of which serves as this paper’s new integrative layer.

Unlike previous four-pillar iterations (Dehghanniri et al., 2015) that relied on linear crime scripts, this layer provides the structural connectivity required to map procedural offender steps to technical exploit dependencies, thereby bridging the gap between behavioural crime science and systemic cybersecurity. Each pillar contributes valuable strengths to the framework; however, when applied in isolation, each may present specific analytical trade-offs. Their systematic integration — specifically augmented by systemic attack-graph analysis — aims to mitigate the analytical fragmentation identified in current literature.

2.1. Goal-oriented requirements engineering

The field of software engineering has long operated under the principle that security cannot be effectively added later as an “add-on” or an afterthought. Instead, Security Requirements Engineering (SRE) has emerged as a sub-discipline dedicated to the early-stage elicitation, analysis, and validation of requirements that safeguard system assets against deliberate malicious interference (Horkoff et al., 2019; Haley et al., 2008). While early SRE methods often relied on static checklists, rigid threat catalogues, or basic architectural threat modelling, these techniques frequently failed to account for the intentional, adaptive, and highly adversarial nature of modern security threats.

An important development occurred with the adoption of Goal-Oriented Requirements Engineering (GORE). Unlike traditional requirements approaches that focus on *what* a system should do, GORE conceptualises goals as prescriptive statements of intent that must be achieved through the orchestrated cooperation of multiple agents, including software components, human actors, and environmental conditions

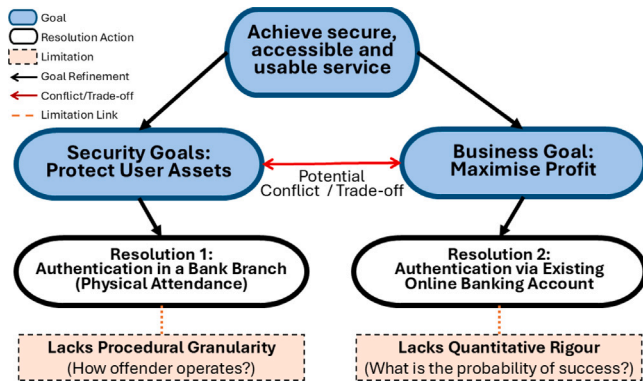


Fig. 1. Partial GORE model illustrating the decomposition of security and usability objectives, along with the identified limitations in procedural granularity and quantitative analysis.

(Horkoff et al., 2019). In GORE, goals are structured into rich, hierarchical models that explicitly capture the dependencies, synergies, and conflicts inherent in complex systems. Security-specific goals — such as “Ensure data integrity” or “Prevent unauthorised credential harvesting” — are refined into operational sub-goals. Crucially, these are balanced against competing non-functional requirements (NFRs) like system usability, operational performance, and profitability, which are often at odds with strict security controls.

These frameworks allow modellers to formally represent *anti-goals* (the objectives of an adversary) and *obstacles* (the threats that prevent goal achievement) (Letier and Van Lamsweerde, 2025).

In the credit-card application fraud case study discussed in this paper, a partial GORE model (see Fig. 1) illustrates the decomposition of high-level objectives like “Achieve secure and usable service”. This hierarchical view allows decision-makers to identify, for instance, how an identity-verification step might satisfy a security goal but inadvertently undermine a usability goal or a business target for rapid customer onboarding. Despite these advantages, GORE typically lacks the procedural granularity to describe *how* an attacker operates or the quantitative rigour to measure the probability of success under uncertainty.

2.2. Risk assessment and the bow-tie analysis

Risk assessment serves as the bridge between abstract goals and the technical reality of threats and vulnerabilities. Contemporary standards, notably ISO 31000 (a widely adopted global reference framework), define risk assessment as a three-stage process: risk identification, risk analysis, and risk evaluation (Ross et al., 2022; Aven, 2008). This work focuses predominantly on the identification and analysis phases, which generate the data-driven inputs necessary for subsequent decision support.

Risk identification is a stakeholder-led process that flags events capable of disrupting organisational objectives. In our chosen identity-theft scenario, the central risk is the “successful fraudulent application for a credit card using a stolen identity”. Once identified, the risk analysis phase seeks to understand the causal chains leading to this event and the resulting impact.

An established tool for this is the *bow-tie diagram*, which provides a symmetrical visualisation of a risk event. Fig. 2 provides the bow-tie analysis for our identity theft case study, highlighting where barriers (resolution actions) can be placed to either prevent the top event or mitigate its impact.

The bow-tie method is increasingly applied in cybersecurity contexts, particularly in critical infrastructure and finance, due to its ability to make complex risk relationships legible to non-technical

stakeholders. However, bow-ties are essentially static and high-level. They identify *what* might go wrong and the *barriers* in place, but they do not provide a “play-by-play” understanding of the offender’s procedural journey. This behavioural gap necessitates the inclusion of crime science.

2.3. Crime scripting and attacker behaviour

Crime science focuses on the environment and the situation in which a crime occurs, rather than the distant psychological background of the offender. A core component of this field is *crime script analysis*, which treats a crime as a structured process rather than a singular event (Dehghanniri and Borrión, 2021). A crime script decomposes an attack into sequential “scenes”—including preparation, entry, commission (the “doing”), and the post-condition (exit and disposal of loot).

This procedural representation is valuable for security designers because it reveals a broader *attack surface* for intervention (Dehghanniri and Borrión, 2021). Instead of focusing solely on preventing the final act of fraud, designers can identify opportunities to disrupt earlier stages, such as preparation or disposal.

To turn these descriptive scripts into prescriptive security measures, our framework utilises the “11 Ds” of Situational Crime Prevention (Ekblom and Hirschfield, 2014). These principles (summarised in Table 1) offer a systematic taxonomy of intervention:

- **Defeat/Disable:** Making the attack physically or technically impossible.
- **Deter:** Increasing the perceived risk of being caught.
- **Discourage:** Reducing the perceived reward or increasing the effort required.
- **Deflect:** Channelling the offender towards a less harmful target (e.g., a honeypot).

By mapping resolution actions to these “Ds”, decision-makers can articulate *how* a specific control is intended to influence an attacker’s decision calculus. However, crime scripts are primarily qualitative. To choose between two different “deterrence” measures, we require the quantitative rigour of decision analysis.

2.4. Quantitative decision and uncertainty analysis

Modern security decisions are rarely made with perfect information. Quantitative Decision Analysis (QDA) provides the mathematical tools to handle this “deep uncertainty” by moving away from binary (yes/no) or simplistic point-estimate judgements. Instead, QDA employs probabilistic modelling, Monte-Carlo simulations, and sensitivity analysis to evaluate the range of possible outcomes for any given resolution action (Letier et al., 2014; Marchau et al., 2019).

The central metric used in this pillar is the *expected loss magnitude* (ELM), which allows for a cost–benefit comparison. The value of a security intervention is defined as the reduction in expected loss (the risk reduction) minus the total cost of implementation and maintenance:

$$\text{Value} = (ELM_{\text{Baseline}} - ELM_{\text{Post-Intervention}}) - \text{Cost}_{\text{Implementation}}$$

2.5. Integrated attack-graph modelling

The final addition to our framework is the inclusion of *attack-graph modelling*. While crime scripts capture the human and procedural steps of an offender, they often fail to capture the underlying technical interdependencies of a modern network. Attack graphs address this by modelling the logical dependencies between various system vulnerabilities and the exploits required to traverse them (Wang et al., 2008).

In complex, cloud-native environments, an attacker rarely follows a single, linear path. They may pivot through multiple microservices, exploit “trust relationships” between containers, and escalate privileges across different security zones. By integrating attack graphs as a fifth pillar, our framework creates a *dual-view* of the threat:

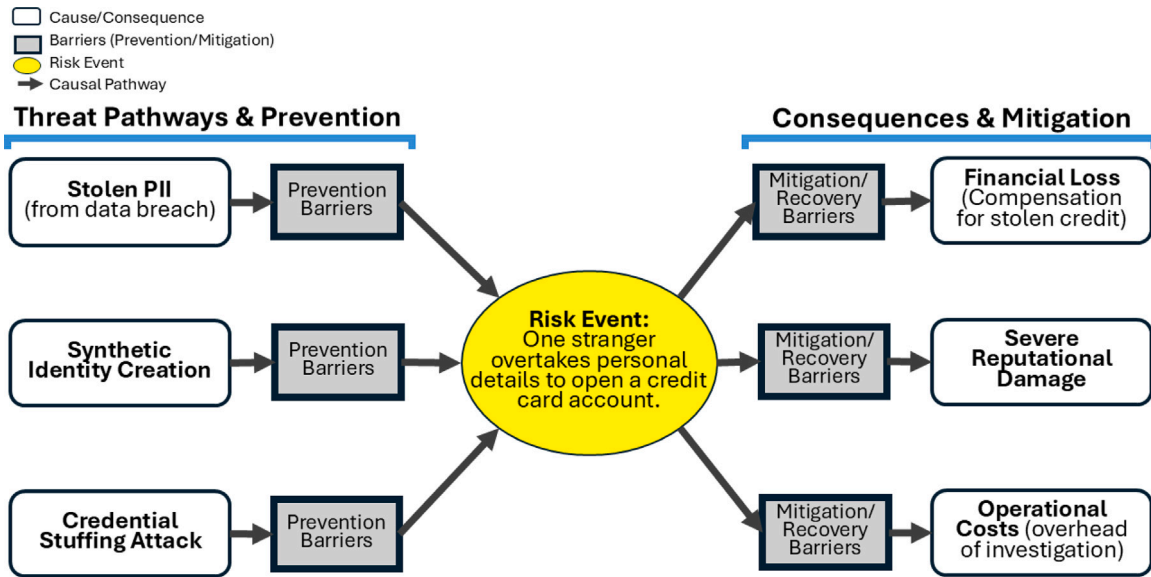


Fig. 2. Bow-Tie Diagram for Identity Theft Risk Assessment. The central risk event (Credit Card Fraud) is connected to diverse threat pathways (left) and potential consequences (right), which are neutralised or amplified by prevention and recovery barriers.

Table 1
The 11 Dimensions (Ds) of Crime Prevention and functional mechanisms (Ekblom and Hirschfield, 2014).

Dimension	Functional mechanism
Defeat	Physically or logically block access, movement, or data gathering.
Disable/Deny	Render adversary tools, equipment, or supporting assets unusable.
Direct/Deflect	Route potential offenders towards or away from specific zones or actions.
Deter-known	Highlight explicit risks to force adversaries to abort due to acceptable detection rates.
Deter-unknown	Leverage operational uncertainty so adversaries judge exposure risks as unacceptable.
Discourage	Increase required effort or decrease operational payout relative to perceived risk.
Demotivate	Disrupt adversary intent via counter-motivations, ethical hurdles, or social friction.
Deceive	Feed adversaries false inputs regarding risk, effort, or targets to induce mistakes.
Disconcert	Trigger involuntary adversary reactions or disruption via sudden surprises or alarms.
Detect	Expose operational presence or anomalies through active and passive monitoring.
Detain	Intercept, apprehend, or uniquely identify offenders post-detection.

- **The Human Procedural View (Crime Script):** Modelling the offender's intent, preparation, and logical steps.
- **The Systemic Technical View (Attack Graph):** Modelling the technical “reachability” and exploit chains within the infrastructure.

Formally, we adopt a logical attack-graph structure consistent with established formulations such as MulVAL (Ou et al., 2005) and TVA (Jajodia et al., 2005), adapted here into a simplified AND/OR-edge representation for expository clarity. The graph is a directed structure comprising two node types: (i) state nodes, representing a system condition or attacker capability the offender has achieved (e.g., “credentials harvested”, “authentication bypassed”); and (ii) exploit nodes, representing the specific technical action or vulnerability exploitation

that transitions the attacker from one state to another (e.g., “credential-stuffing attack against login endpoint”). Edges are directed and typed as either AND-edges, where a state is reachable only if all incoming preconditions are satisfied (e.g., both stolen PII and a bypassed verification check are required before an application can be submitted), or OR-edges, where a state is reachable via any one of several alternative exploit paths (e.g., PII may be obtained via a data breach, credential stuffing, or an insider leak, any of which independently enables the next state). This AND/OR structure is what allows the attack graph to represent multi-path attacker trajectories that a linear crime script cannot.

Edge probabilities represent the likelihood of successful exploitation given that the preconditions are met. In line with established practice (Wang et al., 2008), these may be derived from CVSS exploitability sub-scores where a node corresponds to a known CVE, from historical incident-frequency data, or from structured expert judgement where no such data exists—consistent with the elicitation approach described for the ELM inputs in Section 4.1. For AND-edges, the probability of reaching the downstream state is the product of incoming edge probabilities, reflecting that all preconditions must independently succeed; for OR-edges, it is derived as the probability that at least one incoming path succeeds. In the illustrative case study (Section 4), we assign representative probabilities to demonstrate this propagation mechanism rather than deriving them from empirical exploit data. A worked numerical example of this propagation, reconciled with the case-study ELM baseline, is given in Section 4.2.

This propagation rule carries a simplifying assumption that should be made explicit: multiplying probabilities across AND-edges treats the underlying exploit events as independent, or at most conditionally independent given their stated preconditions. Real attack paths may exhibit correlated vulnerabilities — for example, a single misconfiguration that simultaneously weakens multiple downstream controls — and adaptive attacker behaviour, where an offender revises their approach in response to an encountered barrier rather than treating each step as a fixed, isolated probability. Neither is captured by the simplified AND/OR representation adopted here for expository clarity.

2.6. Distinction from prior four-pillar work

The framework presented in this paper builds upon the four-pillar synthesis of Dehghanniri et al. (2015) (GORE, crime scripting, risk

Table 2

Analytical tasks enabled by the five-pillar framework versus the four-pillar predecessor (Dehghanniri et al., 2015).

Analytical task	Four-Pillar (Dehghanniri et al., 2015)	Five-Pillar (this paper)
Represent single and multi-path attacker trajectories (linear, OR-branching, AND-dependencies)	Linear only	✓
Quantify probability propagation across multi-path exploit chains	–	✓
Identify which specific technical paths a control severs, rather than only which script scene it disrupts	–	✓
Reveal residual attack paths left open after a control is applied (e.g., lateral movement)	–	✓
Map stakeholder goals to procedural and systemic/technical dimensions	Procedural only	✓ (both)

assessment, and quantitative decision analysis) by incorporating *attack-graph modelling* as a fifth, integrative layer. While (Dehghanniri et al., 2015) demonstrated the utility of combining these four disciplines, its reliance on linear crime scripts limits its ability to represent multi-path, systemic attacker behaviour—a limitation noted in Section 2.5 above. Table 2 summarises the specific analytical tasks enabled by the five-pillar framework that are not achievable within the four-pillar predecessor.

The last three rows are demonstrated concretely in the case study: the *dual-view* comparison (Table 7) shows the attack graph revealing three independent OR-paths to PII compromise that the linear crime script represents as a single scene, and Section 4.3 shows Resolution 2 leaving a residual lateral-movement path open—an insight unavailable under a crime-script-only analysis.

2.7. Related integrated frameworks

Beyond the individual pillars reviewed above, several established methodologies already combine multiple security disciplines into a single decision-support process. This subsection positions the proposed framework against three widely adopted approaches: PASTA, OCTAVE, and STRIDE (with attack trees).

PASTA (UcedaVelez and Morana, 2015) is a seven-stage, risk-centric threat modelling methodology that explicitly connects technical vulnerabilities to business impact, sharing our framework's goal of bridging organisational and technical perspectives. However, PASTA's attack-simulation stage does not formally distinguish between a procedural attacker script and a systemic exploit-dependency graph; its threat and attack-tree artefacts are typically constructed and evaluated qualitatively, without the explicit uncertainty-range quantification (Section 2.4) or the *dual-view* mapping (Section 4.2) that our framework provides.

OCTAVE (Alberts and Dorofee, 2001) is an asset-driven, self-directed organisational risk evaluation approach, strong in eliciting stakeholder-defined critical assets and organisational risk tolerance. However, OCTAVE operates primarily at the organisational and asset level; it does not provide a procedural attacker model comparable to crime scripting, nor a technical exploit-dependency structure comparable to *attack-graph modelling*, and it does not formally propagate quantitative uncertainty through candidate mitigation actions.

STRIDE (Shostack, 2014), typically combined with attack trees, offers a systematic taxonomy for enumerating threat categories (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) at the design stage. While effective for exhaustive threat enumeration, STRIDE-based attack trees represent a single

attacker goal as a static decomposition of sub-threats; they do not capture the sequential, procedural offender behaviour central to crime scripting, nor do they attach explicit cost–benefit values to candidate resolution actions.

Table 3 summarises this positioning. While existing frameworks address specific dimensions of the security decision problem, there remains a relative gap in approaches that simultaneously integrate goal-oriented trade-off modelling, procedural attacker behaviour, systemic exploit pathways, and quantitative uncertainty valuation within a single conceptual model.

The following section details the formal specification of this integrated modelling language and the step-by-step process for its application.

3. Integrated resolution action effect evaluation framework

Building upon the five complementary pillars reviewed in Section 2 — Goal-Oriented Requirements Engineering (GORE), Risk Assessment (RA), Crime Script Analysis (CSA), Quantitative Decision Analysis (QDA), and Attack-Graph Modelling (AGM) — this section presents the core contribution of this research: an enhanced, multi-layered Integrated Resolution Action Effect Evaluation Framework.

Rather than simply aggregating these disciplines, this framework aims to synthesise them into a formalised modelling language and a systematic, three-phased evaluation process. Its primary objective is to offer decision-makers structured support for evaluating trade-offs beyond traditional static checklist methods. Instead, it enables the comparison of alternative resolution actions (countermeasures) based on their multi-dimensional impact: how they satisfy competing stakeholder goals, how they disrupt the specific procedural “scenes” of an offender's journey, and how they sever technical exploit dependencies within a systemic, multi-path attack graph.

By making these complex, non-linear relationships more explicit, modelled, quantifiable, and visually integrated under conditions of deep uncertainty, the framework seeks to help address the methodological fragmentation identified in the literature. It offers a practical, visual, and auditable decision-support artefact intended to assist in navigating the complexities of modern, highly distributed socio-technical systems, including cloud-native architectures, IoT ecosystems, and cyber–physical environments. As illustrated in the framework's operational architecture (Fig. 3), the process is structured into three sequential yet iterative phases: (1) Providing Input, (2) Resolution Actions Effects' Evaluation, and (3) Decision-making.

The resulting output is a *Unified Conceptual Model* (Fig. 4) intended to serve as a visual “common operating picture” for evidence-based security management, helping to align executive-level strategy with ground-level technical implementation.

3.1. Formal specification

We define the *Unified Conceptual Model* formally as a tuple:

$$\mathcal{M} = \langle G, S, A, R, V \rangle$$

where:

- $G = \{g_1, \dots, g_n\}$ is the set of stakeholder goals, derived via GORE, each annotated with a type $\in \{\text{security}, \text{NFR}\}$ and connected by refinement or conflict relations (Section 2.1).
- $S = \{s_1, \dots, s_m\}$ is the ordered set of crime-script scenes, each belonging to a phase $\in \{\text{pre-condition}, \text{doing}, \text{post-condition}\}$ (Section 2.3).
- $A = \langle N, E \rangle$ is the attack graph, where $N = N_{\text{state}} \cup N_{\text{exploit}}$ and E is the set of directed AND/OR edges (as formally defined in Section 2.5).
- $R = \{r_1, \dots, r_k\}$ is the set of candidate resolution actions, each identified via the “11 Ds” checklist (Table 1).

Table 3

Positioning against existing integrated security frameworks.

Framework	Goal/NFR trade-offs	Procedural attacker model	Systemic exploit graph	Quantitative uncertainty
PASTA (UcedaVelez and Morana, 2015)	✓	Partial	–	Partial
OCTAVE (Alberts and Dorofee, 2001)	✓	–	–	–
STRIDE + attack trees (Shostack, 2014)	–	–	Partial	–
This paper	✓	✓	✓	✓

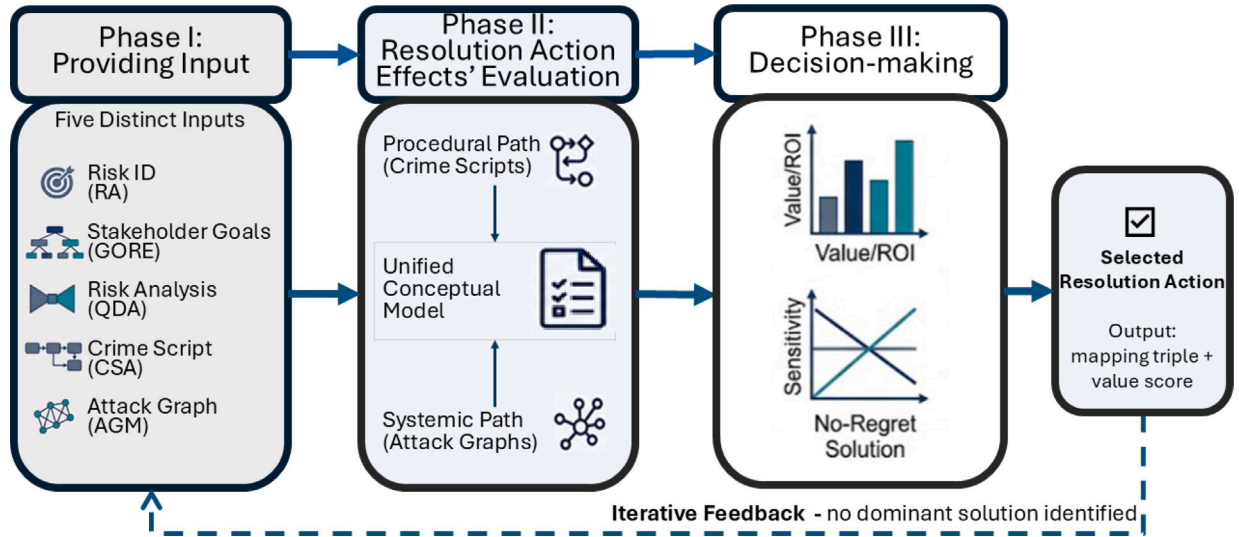


Fig. 3. The Integrated Resolution Action Effect Evaluation Framework: Operational Architecture. The framework systematically flows through (1) Input collection across five multidisciplinary pillars, (2) Dual-Path evaluation of resolution actions against crime scripts and attack graphs, and (3) Evidence-based Decision-making under deep uncertainty, culminating in a robust, auditable selection rationale. The diagram also indicates the framework's iterative feedback condition and its formal outputs (ϕ_S , ϕ_A , ϕ_G , $V(r)$), as defined in Section 3.1.

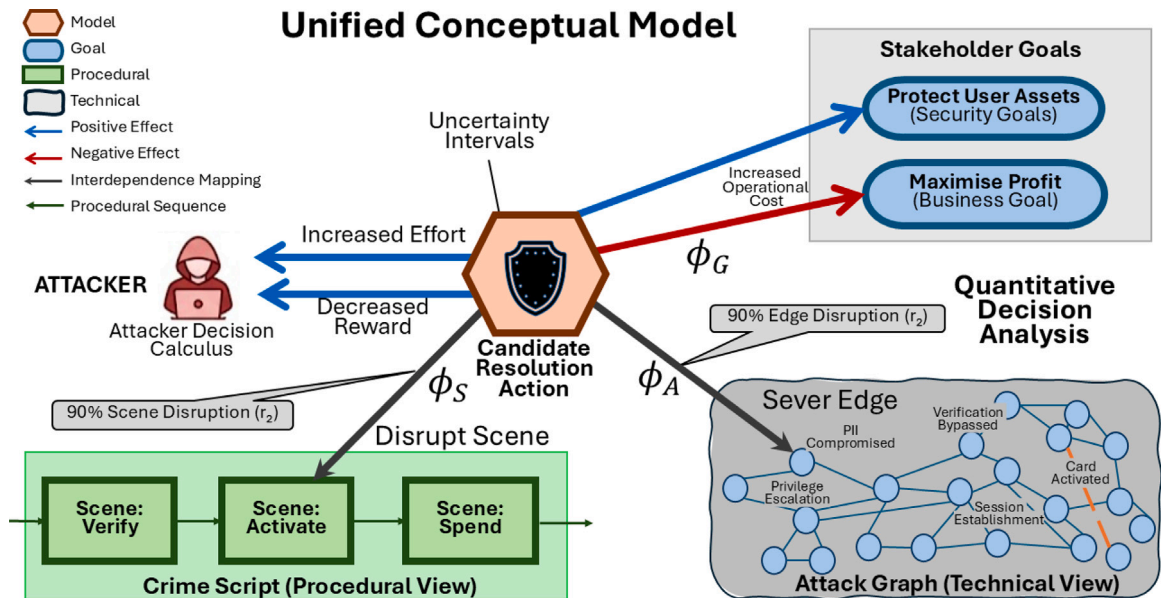


Fig. 4. The *Unified Conceptual Model* applied to Resolution 2: an integrative artefact linking the resolution action to (i) stakeholder goals via ϕ_G (GORE), (ii) attacker decision calculus, (iii) the crime-script scenes it disrupts via ϕ_S (CSA), and (iv) the attack-graph edge it severs via ϕ_A (AGM). Annotations show the illustrative values from the worked calculation (Section 4.1) and formal specification (Section 3.1).

- $V : R \rightarrow \mathbb{R}$ is the *value function* defined as:

$$V(r) = (\text{ELM}_{\text{baseline}} - \text{ELM}_{\text{post-intervention}}(r)) - \text{Cost}(r) \quad (1)$$

where $\text{ELM}_{\text{baseline}}$ represents the baseline Expected Loss Magnitude before any remediation, $\text{ELM}_{\text{post-intervention}}(r)$ is the residual Expected Loss Magnitude remaining after applying response action $r \in R$, and $\text{Cost}(r)$ is the total economic or operational cost incurred by executing action r , following Section 2.4.

Each resolution action $r \in R$ is linked to the other model components via three mapping functions:

$$\phi_S : R \rightarrow 2^S, \quad \phi_A : R \rightarrow 2^E, \quad \phi_G : R \rightarrow G \times \{+, -, 0\}$$

- $\phi_S(r)$ maps a resolution action to the subset of crime-script scenes it disrupts (e.g., the “Activate” scene in Table 6), annotated with the relevant “11 Ds” mechanism (Table 1).
- $\phi_A(r)$ maps a resolution action to the subset of attack-graph edges it severs or weakens, expressed as a probability adjustment Δp_e applied to each affected edge $e \in \phi_A(r)$.
- $\phi_G(r)$ maps a resolution action to the stakeholder goal(s) it affects, together with the polarity of that effect (positive, negative, or neutral), corresponding to the qualitative annotations shown in Fig. 4.

This triple mapping (ϕ_S, ϕ_A, ϕ_G) is what allows a single resolution action to be evaluated simultaneously across the procedural, systemic, and goal-oriented dimensions of the framework, and is what the *Unified Conceptual Model* (Fig. 4) visualises directly.

For example, Resolution 2 (authentication using an existing online banking account) is formally specified as:

$$\phi_S(r_2) = \{\text{Activate}\}, \quad \phi_A(r_2) = \{e_{\text{activation}}\},$$

$$\phi_G(r_2) = \{(\text{Authentication}, +), (\text{Onboarding Speed}, -)\}$$

with $\Delta p_{e_{\text{activation}}} = -0.90$ (a 90% reduction in the probability of successfully traversing the activation edge), consistent with the worked calculation in Section 4.1 and the *dual-view* comparison in Table 7.

This formal specification makes the framework’s reasoning process explicit and reproducible: given any resolution action’s mapping triple ($\phi_S(r), \phi_A(r), \phi_G(r)$) and its associated value $V(r)$, a decision-maker (or automated tool) can systematically reconstruct the comparison performed in Phase III without relying on the visual model alone.

Within this specification, $V(r)$ provides the framework’s quantitative ranking criterion, while $\phi_G(r)$ serves a complementary, deliberative role: it surfaces the qualitative goal-level consequences of the top-ranked action so that stakeholders can scrutinise — rather than silently accept — a numerically superior option with an adverse effect on an important goal. $\phi_G(r)$ does not override the ranking produced by $V(r)$; it supports the negotiation and robustness-checking activities described in Section 3.5

3.2. Algorithmic procedure

Algorithm 1 summarises how the framework transforms the Phase I inputs (stakeholder goals, the risk event, the crime script, and the attack graph) into a ranked set of resolution actions, formalising the reasoning process described narratively in Sections 3.3–3.5.

Applying this procedure to the identity-theft case study (Section 4) with $R = \{r_1, r_2\}$ produces an illustrative ranking Resolution 2 $>$ Resolution 1, consistent with $V(r_2) = +6.0 \times 10^{-2} > V(r_1) = -3.0 \times 10^{-2}$ (Section 4.1), and with the robustness confirmed via sensitivity analysis (Section 4.4).

3.3. Phase I: Providing input

The initial phase is dedicated to the elicitation and assembly of all necessary data. Because the quality of downstream risk and resolution

evaluations depends on the completeness and validity of the input data, this phase ensures that subsequent steps are grounded in stakeholder-validated, multi-perspective information. This phase is divided into five critical tasks that establish the boundary, scope, and mathematical baseline of the security problem.

1. Stakeholders and Goals Identification: This task utilises GORE methodologies (such as KAOS or i*) to identify the primary stakeholders—ranging from executive leadership and asset owners to end-users, system administrators, and regulatory bodies. We construct a hierarchical goal model that captures the inherent tensions within the system. Following established GORE practice (Horkoff et al., 2019), we explicitly model both security-specific goals (e.g., “Ensure non-repudiation of transactions” or “Maintain data confidentiality”) and broader organisational non-functional requirements (NFRs) like “Maximise user onboarding speed”, “Reduce operational friction”, and “Maintain regulatory compliance”.

In GORE, goals are not just abstract desires; they are prescriptive statements of intent. By documenting conflicts (e.g., where a “Strict Identity Verification” goal hinders a “Solid User Experience” goal) early in the process, the framework ensures that security controls are evaluated as a component of the broader business value chain. This prevents the common pitfall where security “solutions” are rejected post-implementation because they disrupt core business functions.

2. Risk Identification: Consistent with ISO 31000 and NIST SP 800-160 standards (Ross et al., 2022; Aven, 2008), stakeholders collaboratively define the specific risk event under consideration. In our running identity-theft case study, this is defined as “the successful fraudulent application for a credit card using a stolen or synthetic identity”. This step functions as a “scoping filter”, helping ensure subsequent modelling focuses on risks deemed material to the organisation’s survival, financial stability, or reputation. It transforms a broad “security problem” into a specific, manageable “decision problem”.

3. Risk Analysis and Hybrid Path Structuring: This task breaks down the identified risk into its causal, procedural, and technical pathways. We employ a three-part approach to help ensure a more thorough coverage of threat pathways:

- Consequence Analysis:* Utilising bow-tie diagrams to map threats to downstream financial, reputational, and legal impacts. This provides the “vertical” view of risk magnitude.
- Procedural Analysis (Crime Scripting):* Applying the crime script model (Dehghanniri and Borrión, 2021) to map the offender’s journey across pre-condition, doing, and post-condition scenes. This reveals the “human” and logistical steps an attacker must take, such as “harvesting data from the dark web” or “testing credentials on a low-security portal”.
- Systemic Analysis (Attack Graphs):* Introducing attack graphs to model the logical exploit dependencies (e.g., lateral movement, SQL injection, or privilege escalation) within the system architecture. This provides the “horizontal” view of technical reachability.

This hybrid structuring is a key feature of the framework; it helps connect high-level risk narratives (the “what”) with the granular, technical exploit chains (the “how”) inherent in modern, API-driven software architectures.

4. Resolution Action Identification: Here, candidate security measures are identified through threat intelligence, historical data, and expert consultation. We utilise the “11 Ds” of Situational Crime Prevention (Ekblom and Hirschfield, 2014) as a systematic checklist. This ensures the selected actions represent a diverse range of strategies—moving beyond technical “Defeat” mechanisms (e.g., encryption) to include psychological “deterrence” (e.g., real-time fraud warnings) and “Discouragement” (e.g., increasing the manual review time for high-risk applications).

5. Preliminary Quantitative Evaluation: Each action is subjected to an initial cost–benefit check using the Expected Loss Magnitude (ELM)

Algorithm 1 Resolution Action Ranking

Require: Goal set G , risk event ρ , crime script S , attack graph $A = \langle N, E \rangle$, candidate resolution actions $R = \{r_1, \dots, r_k\}$

Ensure: Ranked list of resolution actions with value scores

```

1: for each  $r_i \in R$  do
2:   Identify  $\phi_S(r_i) \subseteq S$ 
3:   Identify  $\phi_A(r_i) \subseteq E$ 
4:   for each edge  $e \in \phi_A(r_i)$  do
5:     Apply probability adjustment  $\Delta p_e$  to  $e$ 
6:   end for
7:   Propagate adjusted edge probabilities through  $A$ 
8:   Compute  $\text{ELM}_{\text{post-intervention}}(r_i)$  from propagated graph
9:   Compute  $V(r_i) = (\text{ELM}_{\text{baseline}} - \text{ELM}_{\text{post-intervention}}(r_i)) - \text{Cost}(r_i)$ 
10:  Identify  $\phi_G(r_i)$ 
11:  Run sensitivity check by perturbing inputs within uncertainty ranges
12:  Record  $V(r_i)$  stability
13: end for
14: Rank  $R$  by  $V(r_i)$ , subject to no-regret robustness check (Section 3.5)
15: return Ranked  $R$  with  $(\phi_S, \phi_A, \phi_G, V)$  for each  $r_i$ 

```

formula. ELM represents the probability of a risk event multiplied by its impact. The “Value” of a resolution action is the delta in ELM minus the cost:

$$\text{Value} = (\text{ELM}_{\text{baseline}} - \text{ELM}_{\text{post-intervention}}) - \text{Cost}_{\text{total}}$$

By incorporating uncertainty ranges (using 90% confidence intervals or, where appropriate, Monte Carlo simulations) rather than static point estimates, this task provides a robust early indicator of an action’s potential ROI. This allows the organisation to filter out economically infeasible or “over-engineered” controls before proceeding to the more resource-intensive evaluation phase.

3.4. Phase II: Resolution actions’ effects evaluation

This central phase performs the core multidisciplinary synthesis of the framework. It moves beyond simple financial cost–benefit analysis to model the *mechanics* of prevention across both the human (procedural) and technical (systemic) dimensions of the attack.

1. Assessing Action Effects on the Dual-Path Model: For every candidate action, we investigate exactly which crime-script scenes are disrupted and which attack-graph edges are severed. We use the “11 Ds” as an analytical lens to determine the “mode of interference”.

For example, consider the implementation of an “AI-Driven Behavioural Biometric” system. In the crime script, this action may serve as a “Deterrent” in the “Doing” scene, as the offender realises their typing patterns or mouse movements will be flagged. Simultaneously, in the attack graph, this action increases the “Exploit Difficulty” metric on the authentication node, effectively making that path through the network significantly more “expensive” for the attacker in terms of time and resources. This mapping demonstrates the “defence in depth” provided by the control, showing where the adversary is interrupted in their procedural flow and where the system’s technical paths are blocked. This *dual-view* helps to ensure that a control is not just a “partial barrier” for a human offender but a “dead end” in the technical architecture.

2. Developing the Unified Conceptual Model: This task produces the framework’s primary modelling artefact. The model integrates five core entities:

- Victim Goals: The GORE-derived objectives of the organisation.
- Attacker Model: The offender’s goals (e.g., financial gain) and their decision calculus (effort vs. reward).
- Resolution Actions: The proposed countermeasures.
- Crime Script: The step-by-step procedural scenes of the attack.
- Attack Graph: The technical exploit nodes and edges.

Fig. 4 instantiates this model for Resolution 2 from the case study (Section 4), showing the resolution action’s mappings $\phi_S(r_2)$, $\phi_A(r_2)$, and $\phi_G(r_2)$ as introduced formally in Section 3.3.

Relationships are represented using directed links annotated with qualitative effects (positive/negative/neutral) and quantitative metrics (e.g., percentage reduction in attack success probability). This visual integration allows decision-makers to see “ripples” throughout the system. For instance, they can see if a control that satisfies a “Security” goal inadvertently sends a “Negative” link to a “Profitability” goal due to increased friction. This transparency is vital for cross-departmental communication between IT, Finance, and Legal teams.

3.5. Phase III: Decision-making

The final phase leverages the *dual-view* insights from Phase II to support a transparent and defensible selection process. Security decisions are often made under pressure, so this phase provides a systematic structure intended to help align decisions with strategic goals. Decision-makers can thus employ three distinct forms of reasoning:

1. Comparison: Alternatives are evaluated based on their combined impact across the entire goal hierarchy and the expanded *attack surface*. We look for the “dominant” solution—one that provides the greatest risk reduction for the least impact on non-security goals. This ensures that the chosen solution is the one that provides the best balance of risk reduction and business enablement.

It is the value function $V(r)$ that determines this quantitative ranking; $\phi_G(r)$ is deliberately not incorporated into $V(r)$ as an additional scoring term. Instead, it is surfaced alongside the ranking so decision-makers can flag cases where the top-ranked action carries a significant adverse effect on an important stakeholder goal, prompting further negotiation (see Trade-off Visualisation and Negotiation, below) rather than overriding the result.

2. Trade-off Visualisation and Negotiation: By making hidden conflicts explicit, the framework allows stakeholders to “design the trade-off” intentionally. If a high-security measure is known to reduce user conversion by 5%, the marketing team and the security team can negotiate based on data rather than intuition. This is crucial for gaining buy-in from non-technical executives who must balance security with operational efficiency and growth.

3. Robustness Checking under Deep Uncertainty: Utilising sensitivity analysis on the ELM ranges and attack-graph probabilities, we identify “no-regret” solutions (Loomes and Sugden, 1982). In the context of 2026’s volatile threat landscape, a no-regret solution is a control that tends to maintain strong performance across a wide variety

of possible future scenarios—including a sudden increase in attacker sophistication (e.g., AI-automated scripts) or a fluctuation in implementation costs. This mathematical property supports system robustness, even if the initial assumptions about the threat landscape turn out to be slightly inaccurate.

Rather than attempting to replace human judgement, the framework seeks to provide an analytically grounded, visual rationale intended to assist in demonstrating “required checks” to auditors, regulators, and boards of directors. In regulated environments like the financial sector, providing a structured rationale for control selection can enhance auditability and strategic alignment. Accordingly, this approach helps demonstrate how security investments extend beyond simple technical expenses to align with the long-term resilience and strategic objectives of the modern organisation.

While a full regulatory mapping is beyond the scope of this paper (see Section 5), the framework’s outputs align naturally with existing compliance documentation requirements relevant to finance and critical-infrastructure organisations. The EU NIS2 Directive’s Article 21 risk-management measures require documented policies on risk analysis, incident handling, and the assessment of security measures’ effectiveness (European Parliament and Council, 2022a); the framework’s *Unified Conceptual Model* and its formal mapping triple (ϕ_S, ϕ_A, ϕ_G) (Section 3.1) provide exactly this kind of auditable evidence trail, showing which specific risks a control addresses and why. Similarly, the EU Digital Operational Resilience Act (DORA) requires financial entities to maintain a documented ICT risk-management framework with evidence of control effectiveness (European Parliament and Council, 2022b); the framework’s value function $V(r)$ and sensitivity analysis (Section 3.5) offer a quantitative basis for such evidence. For organisations pursuing SOC 2 attestation, the framework’s explicit mapping of controls to specific threats and outcomes supports the kind of control-rationale documentation SOC 2 audits typically require. We do not claim the framework satisfies any of these regimes on its own, but its auditable, evidence-based outputs are structurally well-suited to the documentation these frameworks demand.

3.6. Evaluation criteria

To move beyond purely qualitative assessment, we propose a set of measurable indicators against which the framework’s outputs — and future empirical applications of it — can be evaluated. These criteria are proposed here as an evaluation protocol for future validation studies (Section 5); the present paper does not report results against them, consistent with its demonstrative rather than empirical scope (Section 4).

- **Script coverage:** the proportion of crime-script scenes $s \in S$ for which at least one candidate resolution action has a non-empty mapping $\phi_S(r)$ (Section 3.1). Low coverage indicates procedural stages left unaddressed by the candidate action set.
- **Graph coverage:** the proportion of attack-graph edges $e \in E$ for which at least one candidate action has a non-empty mapping $\phi_A(r)$. This quantifies the extent to which the candidate controls address the full space of technical exploit paths, rather than only the paths visible in the crime script.
- **Inter-rater consistency:** when multiple analysts independently construct the mappings ϕ_S , ϕ_A , and ϕ_G for the same resolution action, agreement can be quantified using Cohen’s kappa or Fleiss’ kappa across raters.
- **Decision stability under uncertainty:** the proportion of sensitivity-analysis perturbations (Section 3.5) under which the top-ranked resolution action remains unchanged. This operationalises the “no-regret” property discussed qualitatively in Section 3.5 into a measurable robustness score.
- **Time-to-decision:** the elapsed analyst time required to complete Phases I–III for a given risk event, providing a scalability indicator for practical deployment alongside the analytical outputs.

These indicators are illustrated qualitatively using the case study in Section 4: for example, Table 8 shows that both candidate resolutions map to only three of seven script scenes, yielding a script coverage of approximately 43% for either action in isolation—a quantitative expression of the observation made in Section 4.3 that both resolutions target early-stage vulnerabilities.

4. Demonstrative application: Identity-theft in financial services

To illustrate the operational mechanics and potential decision-support capability of the enhanced framework, this section applies it to a realistic and persistent security risk: identity theft in the form of “setting up a credit card using a stolen identity”. This case remains highly relevant in 2026. According to the latest Cifas Fraudscape 2026 report, identity fraud still accounts for over 54% of all reported fraud cases in the United Kingdom, with criminals increasingly exploiting synthetic identities, stolen personal data, and automated online application processes (Cifas, 2026).

The values, probability estimates, and cost figures used throughout this application are illustrative constructs designed to demonstrate the framework’s mechanics; they are not derived from empirical organisational data or practitioner elicitation, and should not be read as validated estimates.

The framework is used to evaluate two candidate resolution actions, incorporating the full set of five pillars: Goal-Oriented Requirements Engineering (GORE), Risk Assessment (RA), Crime Script Analysis (CSA), Quantitative Decision Analysis (QDA), and Attack-Graph Modelling (AGM). By producing the *Unified Conceptual Model*, this application illustrates how the multidisciplinary approach generates actionable insights that are likely to be more difficult to obtain using any single discipline in isolation. Specifically, it highlights the tension between security rigour and business operational efficiency—a classic dilemma for financial institutions.

4.1. Phase I: Providing input

In a real deployment, the components of the ELM formula would be derived empirically rather than assumed: baseline and post-intervention attack-probabilities would be estimated from historical incident data, red-team exercises, or structured expert elicitation (e.g., the Delphi method); impact and cost figures would draw from actual loss records, vendor quotes, and staffing models; and the resulting uncertainty would be propagated through Monte Carlo simulation using distributions fitted to this data (e.g., triangular or PERT distributions for expert-elicited estimates). To demonstrate the calculation structure of the framework without requiring proprietary organisational data, the illustrative case study below substitutes constructed placeholder values for these inputs; a full empirical derivation is identified as future work (Section 5).

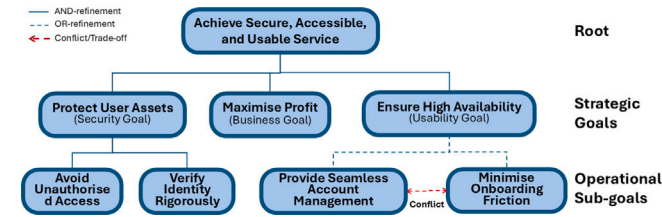
To make this calculation auditable, Table 4 shows the illustrative inputs and resulting arithmetic for both resolutions. We define ELM as the baseline attack-success probability multiplied by a normalised impact value (set to 1, representing loss as a proportion of exposed transaction value). For Resolution 1, an assumed baseline success probability of 0.08 is reduced by 99.9%, giving a post-intervention probability of 0.00008 and an ELM reduction of 0.0799.

Both the ELM reduction and the implementation cost are expressed on a common, normalised basis — as a proportion of exposed transaction value — so that the two quantities in the Value formula are directly comparable before subtraction. Against an illustrative implementation cost of 0.11 (reflecting branch staffing overhead and estimated customer attrition), this yields $\text{Value}_1 = 0.0799 - 0.11 \approx -3.0 \times 10^{-2}$. For Resolution 2, the same baseline probability is reduced by 90%, giving a post-intervention probability of 0.008 and an ELM reduction of 0.072. Against a lower illustrative cost of 0.012, this yields $\text{Value}_2 = 0.072 - 0.012 = +6.0 \times 10^{-2}$. This worked calculation is intended to expose

Table 4

Worked calculation for Resolution 1 and Resolution 2.

Parameter	Resolution 1	Resolution 2
Baseline probability	0.08	0.08
Probability reduction	99.9%	90%
Post-intervention probability	0.00008	0.008
ELM reduction (risk reduction)	0.0799	0.072
Implementation cost (normalised)	0.11	0.012
Net value	-3.0×10^{-2}	$+6.0 \times 10^{-2}$

**Fig. 5.** Security Goal Model (GORE): Illustrating the hierarchical refinement of stakeholder objectives and the inherent conflict between identity verification and customer onboarding friction.**Table 5**

Formal definition of the risk event.

Entity	Description
Risk ID	R-ID-01
Event title	Fraudulent Account Opening via Identity Theft
Description	An unauthorised actor (stranger) overtakes a victim's personal details to open a credit card account. The offender collects the card from the delivery point and spends the credit, which is subsequently debited from the victim.
Impacted assets	Customer Credit, Bank Reputation, Operational Resources.
Primary threat	Sophisticated Identity Fraud (Synthetic or Stolen PII (Personally Identifiable Information)).

the mechanics of the Value formula transparently; the specific inputs remain illustrative, as noted above.

We identify the credit-card company as the primary stakeholder responsible for designing and implementing mitigation measures. Its security goal model, shown in Fig. 5, includes high-level objectives such as “Achieve secure, accessible and usable service”. These are refined into operational sub-goals, including “Avoid unauthorised access to user’s account”, “Protect user assets”, “Provide available account management service”, and the overarching business goal “Maximise profit”. The goal model is elicited and validated using standard GORE techniques, with explicit documentation of conflicts and dependencies. In our 2026 context, a significant conflict exists between the goal “Ensure Rigorous Identity Verification” and “Minimise Customer Onboarding Time”. This hierarchical structure serves as the evaluation baseline against which all resolution actions will be assessed, ensuring that security improvements are aligned with broader organisational priorities rather than technical metrics alone.

The risk event is clearly stated (Table 5, retained from the original analysis): “One stranger can overtake a person’s personal details to open a credit card account. Then he collects the credit card from the delivery point and spends the victim’s credit, which will be debited from him/her”. Consequence analysis via the bow-tie diagram (Fig. 2) identifies the main outcome as financial loss (compensation for stolen credit plus high overhead costs), which directly conflicts with the core security goal of protecting user assets. Industry reporting on aggregate fraud losses (e.g., Cifas (2026)) suggests the scale of this risk category is substantial, though the specific figures used in this illustrative case study are constructed for demonstration purposes.

Table 6

Crime script for identity theft: Credit card application fraud.

Script scene	Phase	Script action
Pre-condition	Prep	Acquiring victim PII and synthetic data from dark-web markets.
	Entry	Accessing the banking portal via a residential VPN to mask the location.
Doing	Apply	Submitting the fraudulent form using automated scripts or manual entry.
	Verify	Bypassing or spoofing basic identity verification checks.
	Activate	Receiving and activating the physical or digital card.
Post-condition	Spend	Executing high-value transactions or cash withdrawals.
	Exit	Laundering funds or abandoning the account before detection.

Crime-script structuring produces a detailed procedural model of the attacker’s process (see Table 6). The script follows Cornish’s classic structure with three distinct phases:

- 1. Pre-condition:** Identifying a vulnerable target, purchasing stolen Personally Identifiable Information (PII) from dark-web marketplaces, and selecting a credit-card provider with perceived weak verification.
- 2. Doing:** Completing the online application using a VPN to mask geolocation and successfully passing basic automated credit checks.
- 3. Post-condition:** Intercepting the physical card from the mail or redirecting it to a drop-address, activating the card, and executing high-value transactions.

To strengthen systemic insight, *Attack-Graph Modelling (AGM)* is constructed in parallel with the crime script. These graphs model logical dependencies among exploits (e.g., Data Breach → Credential Stuffing → Synthetic Identity Creation → Successful Application). While the crime script focuses on the offender’s intent and physical actions, the attack graph reveals the technical “reachability” within the bank’s API infrastructure and cloud databases. This hybrid input phase, therefore, combines high-level consequence mapping (bow-tie), procedural detail (crime script), and network-oriented dependency analysis (attack graph), providing a foundation for subsequent evaluation.

Two realistic and practical resolution actions are considered, both identified via the “11 Ds” checklist and cross-checked against attack-graph vulnerabilities:

Resolution 1 — Authentication in a bank branch: The new credit card can only be activated after in-person identity verification at a physical branch by the legitimate cardholder. This represents a “High-Touch” security approach.

Resolution 2 — Authentication using an online banking account: Activation requires the cardholder to log into an existing online banking account registered in their exact name. This represents a “High-Tech” digital-first approach.

Using illustrative plausible ranges (not derived from empirical benchmarking), Resolution 1 yields an estimated net value of approximately -3.0×10^{-2} (indicating a net cost driven by high operational overhead and customer attrition), while Resolution 2 yields $+6.0 \times 10^{-2}$ (net benefit). These figures incorporate explicit uncertainty ranges in attack-probability reduction (99.9% for Resolution 1 versus 90% for Resolution 2—illustrative values chosen to reflect the higher procedural friction of in-person verification, rather than estimates derived from empirical data) and implementation costs, following QDA best practice in representing uncertainty via ranges rather than point estimates (Letier et al., 2014; Marchau et al., 2019). Monte Carlo simulation was not performed in this demonstrative application. In a full implementation, attack-graph probabilities would be propagated through Monte-Carlo simulation to refine ELM estimates under uncertainty; for

Table 7

Dual-view comparison: Crime-script scenes versus attack-graph representation for the identity-theft case study.

Crime script scene	Attack graph representation	What the graph reveals (Script cannot)
Prep: Acquire PII from dark-web markets	State node “PII Compromised”, reachable via 3 OR-edges: Data Breach ($p = 0.4$), Credential Stuffing ($p = 0.3$), Insider Leak ($p = 0.1$)	Multiple independent technical paths to the same attacker capability
Entry: Access portal via VPN	(no direct graph node—procedural/behavioural, not a system-state transition)	–
Doing/Verify: Bypass identity checks	State node “Verification Bypassed”, AND-edge requiring both “PII Compromised” AND “Automated Check Weakness” exploited	Explicit precondition dependency structure
Post-condition/Activate: Activate card	State node “Card Activated”, single AND-edge from “Verification Bypassed”	Convergence point—where Resolution 1/2 sever the graph

this illustrative example, we instead apply the point-estimate ranges directly to demonstrate the calculation structure.

4.2. Dual-view comparison

To demonstrate the *dual-view* claim concretely, Table 7 presents the same attack — fraudulent credit-card application via identity theft — represented in parallel as crime-script scenes and as attack-graph nodes. The crime script (Table 6) presents the attacker’s journey as a single linear sequence of human actions. The attack graph reveals that the “Pre-condition” scene (acquiring PII) is not a single step but a branch point: PII may be obtained via any of three independent exploit paths (data breach, credential stuffing, or insider leak), each with a different probability and each requiring a different resolution action to block. This is the systemic detail the crime script abstracts away: a control that blocks credential stuffing (e.g., rate-limiting on the login endpoint) leaves the data-breach and insider-leak paths untouched, even though all three appear as the single scene “Acquiring victim PII” in the crime script. Conversely, the crime script reveals procedural/behavioural detail — the attacker’s use of a residential VPN to mask geolocation — that has no natural representation as a graph node, since it does not correspond to a discrete system-state transition. This side-by-side view substantiates the framework’s central claim: the two representations are complementary rather than redundant, each exposing intervention opportunities invisible to the other.

To make this propagation mechanism concrete, consider the three OR-edges feeding the “PII Compromised” state in Table 7: $P(PIICompromised) = 1 - (1 - 0.4)(1 - 0.3)(1 - 0.1) = 1 - 0.378 = 0.622$. Reconciling this with the 0.08 baseline attack-success probability used in Table 4 requires the downstream AND-edge input, “Automated Check Weakness”, to take a value of $p \approx 0.129$, since $0.622 \times 0.129 \approx 0.08$ —consistent with Section 4.1’s stated use of illustrative, constructed parameter values rather than empirically derived ones. This demonstrates the AND/OR propagation mechanism specified in Section 2.5 and Algorithm 1, reconciled here with the ELM baseline used in the quantitative evaluation.

4.3. Phase II: Resolution actions effect evaluation

Assessing the Effect on the crime script and attack graphs highlights actionable intervention points. Both resolutions affect the same two critical steps in the crime script:

Selecting a credit card company (pre-condition phase): Informed offenders are deterred via the *Deter-known* principle. Criminal forums

Table 8

Mapping of security resolutions to crime script steps.

Script action	RES. 1	RES. 2
Preparation (Stolen Credentials)	–	–
Entry (Initial System Access)	–	–
Apply (Submitting Application)	–	–
Verify (Identity Verification)	✓✓	✓
Activate (Final Service Unlock)	✓✓	✓
Spend (Account Takeover)	✓	✓✓
Exit (Cleanup/Trace Removal)	–	–

often rank banks based on the ease of activation; requiring branch visits or existing account linkages increases the perceived effort (E) and risk (R) for the attacker.

Activating the card (boundary of doing/post-condition): The offender is stopped via the *Defeat* principle because the physical or digital “token” required for activation is not in their possession.

Resolution 1 appears stronger in terms of security magnitude within this scenario, as physical branch attendance typically presents a higher barrier to remote automated exploit pathways. However, the AGM further shows that Resolution 1 severs multiple downstream exploit paths (e.g., automated credential stuffing followed by remote activation), while Resolution 2 primarily disrupts only the final activation node. No meaningful effect is observed on the other eight script steps, confirming that both resolutions target early-stage vulnerabilities rather than post-activation misuse. The mapping table (Table 8) makes these relationships explicit and auditable for the stakeholders.

Modelling the Integrated Effects produces the *Unified Conceptual Model* (Fig. 6). This model is the core artefact of the framework, as it allows for the visualisation of “rippling effects” across the system. The model simultaneously displays:

Goal Impact: A strong positive contribution of both resolutions to the “Authentication” and “Integrity” goals. However, Resolution 1 shows a deep red “Negative” link to the “Customer Availability” and “Operational Profit” goals.

Attacker Calculus: Annotations showing an increase in “Offender Effort” by a factor of 10 for Resolution 1 and a factor of 4 for Resolution 2.

Procedural Disruption: The crime script is marked with symbols at the “Activation” step, showing where the flow is halted.

Systemic Disruption: The attack graph shows three major exploit chains being broken by Resolution 1, whereas Resolution 2 severs one primary path but leaves a “lateral movement” path open if the online banking account itself is compromised.

The visual integration helps make trade-offs more explicit. While Resolution 1 provides a restrictive security posture, its considerable impact on business profitability — due to the cost of staffing branches for verification and the loss of customers who refuse to travel — makes it a problematic choice in a competitive digital economy.

4.4. Phase III: Decision-making

The *Unified Conceptual Model* and supporting quantitative metrics enable clear, evidence-based comparative reasoning. Decision-making in this framework moves away from “gut feelings” towards a structured trade-off analysis.

Resolution 1 satisfies the authentication goal and strongly deters the attacker across both procedural and systemic dimensions, but harms availability and profitability. In a 2026 banking environment where customer retention is as critical as security, the negative net value of Resolution 1 (-3.0×10^{-2}) makes it difficult to justify to the board of directors. Resolution 2 achieves comparable (though slightly lower)

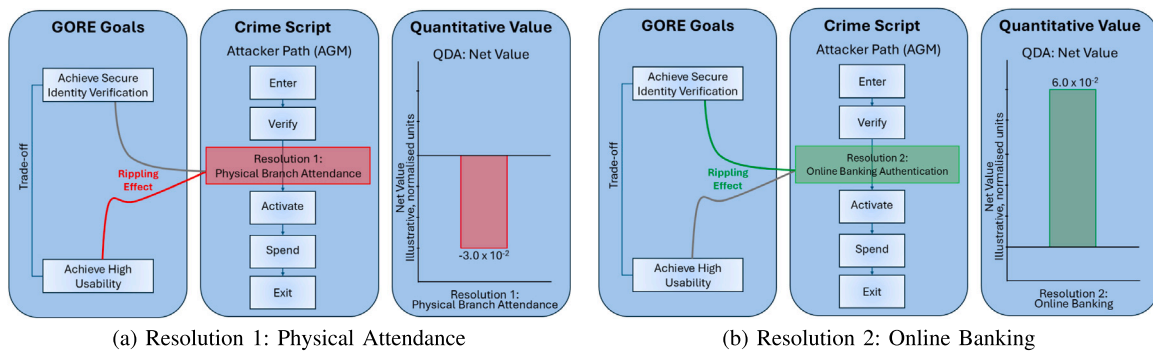


Fig. 6. Unified Conceptual Model of the fraud case study, displaying the integration of goal modelling, procedural analysis, and quantitative evaluation. The horizontal layers visualise the system-wide rippling effects of Resolution 1 (Physical Attendance) and Resolution 2 (Online Banking Account) across security, usability, and business value.

crime-script disruption and attacker deterrence while delivering a positive net value ($+6.0 \times 10^{-2}$) and better alignment with availability and profit goals.

This ranking is driven primarily by the cost differential between the two resolutions rather than by their risk-reduction magnitude: Resolution 1 achieves the larger ELM reduction (0.0799 vs. 0.072), and only falls behind Resolution 2 in net Value because its illustrative implementation cost is approximately nine times higher (0.11 vs. 0.012)—a gap not overturned by the $\pm 20\%$ cost-sensitivity band applied in Section 3.5, and reachable directly from Table 4 figures without the attack-graph analysis. The attack-graph and crime-script dimensions instead contribute procedural and systemic insight into where and how each resolution intervenes (Sections 4.2, 4.3), which the cost comparison alone does not reveal. The result should therefore be read as riding substantially on the illustrative cost assumptions in Table 4, not as a demonstration that Resolution 2 is the more security-effective control.

Sensitivity analysis on the uncertainty ranges (e.g., varying attack probability $\pm 15\%$, cost estimates $\pm 20\%$, or attack-graph edge probabilities $\pm 10\%$ —illustrative perturbation ranges chosen to test qualitative robustness, not derived from empirical variance data) suggests, within this illustrative example, that Resolution 2 remains the preferable choice across all plausible future scenarios. Even under scenarios of heightened attacker sophistication targeting online banking credentials, Resolution 2 tends to maintain superior robustness, owing to cost margins that permit subsequent supplemental “layering” of security.

Thus, under the assumptions of this illustrative model, Resolution 2 (authentication using an existing online banking account) emerges as the preferable option. It demonstrates how the multidisciplinary integration — particularly the addition of AGM — reveals nuanced trade-offs and systemic effects that would be invisible if any single discipline were used in isolation.

4.5. Results

The application of the enhanced framework to this identity-theft case illustrates four key benefits:

Precision in Prevention: Explicit mapping of resolution actions to both crime-script steps and attack-graph paths can enhance the precision of situational prevention measures. This serves to align controls more directly with the specific technical and procedural bottlenecks of the offender, rather than relying on generalised security measures.

Stakeholder Transparency: Simultaneous visualisation of goal satisfaction and systemic impact supports multi-criteria trade-off analysis. This is particularly valuable for communicating with non-technical

stakeholders (e.g., CEOs or Marketing Directors) who need to understand *why* a security measure is being proposed despite its costs.

Robustness under Deep Uncertainty: Explicit handling of uncertainty through ranges and sensitivity analysis facilitates more defensible decision-making. Given the volatility of contemporary threat landscapes, relying solely on point estimates may obfuscate underlying risk dynamics; incorporating probabilistic propagation through attack graphs would provide a more realistic depiction of system vulnerabilities.

Unified Language: The hybrid modelling language (GORE + CSA + AGM) provides a single visual artefact that integrates procedural, systemic, and value-based perspectives. This “common operating picture” reduces the friction between software engineers, crime scientists, and business analysts.

The case study also highlights important practical limitations. First, the framework’s effectiveness depends heavily on the quality of the initial inputs; if the attack graph is missing a critical lateral movement path, the evaluation of Resolution 2 may be overly optimistic. Second, while the approach scales well for focused risks, highly complex multi-stage attacks (e.g., state-sponsored supply-chain compromise) may require automated attack-graph generation tools to remain manageable. Third, in operational settings, integration with real-time fraud intelligence feeds could allow for “Dynamic Evaluation”, where the conceptual model is updated as new attacker techniques emerge.

Overall, the illustrative application indicates that the proposed framework offers a structured, promising avenue for multi-criteria decision support. It equips security teams with a visual and multi-disciplinary tool that bridges previously fragmented perspectives and directly contributes to more effective, cost-efficient, and defensible security investments in the face of evolving 2026 threats.

5. Conclusion and future work

This article has presented an integrated, multidisciplinary modelling language and an enhanced integrated decision-support framework aimed at addressing analytical fragmentation in security decision-making under conditions of deep uncertainty. As modern socio-technical environments, ranging from cloud-native microservices to cyber-physical IoT ecosystems, become increasingly interconnected, traditional fragmented security assessments have appeared insufficient. By systematically synthesising five complementary pillars — Goal-Oriented Requirements Engineering (GORE), Risk Assessment (RA), Crime Script Analysis (CSA), Quantitative Decision Analysis (QDA), and Attack-Graph Modelling (AGM) — the framework enables an evaluation of resolution actions. It maps the multi-dimensional effects of each candidate control onto stakeholder goals, the attacker’s procedural journey, technical exploit paths, and quantitative risk metrics. The resulting *Unified Conceptual Model* serves as a clear, visual, and auditable

artefact that improves both the rigour and transparency of security governance. The illustrative application to identity theft, specifically, the setting up of a credit card using a stolen identity, has illustrated the framework's potential practical utility. In the current 2026 landscape, where identity fraud remains the dominant threat vector accounting for over 54% of UK fraud cases (Cifas, 2026), the case study revealed that two competing resolution actions produce markedly different systemic effects. Resolution 1 (branch-based authentication) delivers superior security magnitude but is estimated to incur a net negative value due to conflicts with customer availability and profitability. Resolution 2 (online-banking authentication) emerged as the no-regret solution, delivering a positive net value while maintaining business continuity and still disrupting critical crime-script steps. These findings, which balance technical defeat with business friction, are difficult to capture through single-discipline methods and provide a defensible rationale for high-stakes investment in finance and critical infrastructure. The framework contributes to addressing long-standing fragmentation in security requirements engineering. Traditional GORE approaches identify goal trade-offs but lack the ground-level view of attacker mechanics; our integration of crime scripts supplies the necessary procedural granularity. Incorporating *attack-graph modelling* further addresses a major weakness in classical crime science by accounting for systemic, multi-path exploit dependencies in digital architectures. Supported by QDA's explicit uncertainty analysis and uncertainty modelling, the framework moves security decision-making towards a more quantitative, evidence-informed approach. This approach directly supports the security-by-design mandate, ensuring that controls are strategically aligned with both organisational mission and the adversary's decision calculus.

Future work will focus on developing a cloud-native prototype to automate the construction of the *Unified Conceptual Model* using LLMs and integrating it with attack-graph tools, alongside large-scale empirical validation in industrial and academic settings with real-world datasets. This empirical work will apply the evaluation criteria proposed in Section 3.6 (script/graph coverage, inter-rater consistency, decision stability, and time-to-decision) and will include grounding the framework's probability estimates through structured expert elicitation, replacing the illustrative point estimates used in the present demonstration with Monte-Carlo propagation over empirically fitted distributions. We will also extend the framework to model adaptive attacker behaviour through AI-driven simulation and investigate regulatory alignment with NIS2, DORA, and the EU AI Act.

In conclusion, by bridging requirements engineering, crime science, systemic exploit modelling, and decision analysis, this framework provides a timely and practical contribution to the field. It contributes towards transitioning security decision-making from ad-hoc intuition towards a more structured, auditable evaluation of trade-offs.

Declaration of generative AI and AI-assisted technologies in the manuscript preparation process

During the preparation of this work, the author used generative AI tools to assist with language editing and refining the presentation of the manuscript. The author reviewed and edited the output as needed and takes full responsibility for the content of the published article.

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgements

The author would like to thank the anonymous reviewers for their constructive comments and insightful suggestions, which have significantly improved the quality and clarity of this manuscript.

Data availability

No data was used for the research described in the article.

References

- Alberts, C., Dorofee, A., 2001. OCTAVE Criteria, Version 2.0. Tech. Rep. CMU/SEI-2001-TR-016, Software Engineering Institute, Carnegie Mellon University.
- Aven, T., 2008. Risk Analysis: Assessing Uncertainties Beyond Expected Values and Probabilities. John Wiley & Sons.
- Bødker, A., Connolly, P., Sing, O., Hutchins, B., Townsley, M., Drew, J., 2023. Card-not-present fraud: using crime scripts to inform crime prevention initiatives. *Secur. J.* 36 (4), 693–711.
- Cifas, 2026. Fraudscape 2026: Reported Fraud Hits Record Levels. Tech. Rep., Cifas, London, [Online]. Available: <https://www.cifas.org.uk/newsroom/fraudscape2026>.
- Dehghanniri, H., Borrión, H., 2021. Crime scripting: A systematic review. *Eur. J. Criminol.* 18 (4), 504–525.
- Dehghanniri, H., Letier, E., Borrión, H., 2015. Improving security decision under uncertainty: A multidisciplinary approach. In: 2015 International Conference on Cyber Situational Awareness, Data Analytics and Assessment. CyberSA, IEEE, pp. 1–7.
- Eklblom, P., Hirschfeld, A., 2014. Developing an alternative formulation of SCP principles—the ds (11 and counting). *Crime Sci.* 3 (1), 2.
- European Parliament and Council, 2022a. Directive (EU) 2022/2555 of the European parliament and of the council (NIS2). Official Journal of the European Union, L 333.
- European Parliament and Council, 2022b. Regulation (EU) 2022/2554 of the European parliament and of the council on digital operational resilience for the financial sector (DORA). Official Journal of the European Union, L 333.
- Haley, C.B., Laney, R., Moffett, J.D., Nuseibeh, B., 2008. Security requirements engineering: A framework for representation and analysis. *IEEE Trans. Softw. Eng.* 34 (2), 133–153.
- Holt, T.J., Lee, J.R., 2022. A crime script analysis of counterfeit identity document procurement online. *Deviant Behav.* 43 (3), 285–302.
- Horkoff, J., Aydemir, F.B., Cardoso, E., Li, T., Mate, A., Paja, E., Salnitri, M., Mylopoulos, J., 2019. Goal-oriented requirements engineering: An extended systematic mapping study. *Requir. Eng.* 24 (2), 133–160.
- Jajodia, S., Noel, S., O'Berry, B., 2005. Topological analysis of network attack vulnerability. In: Kumar, V., Srivastava, J., Lazarevic, A. (Eds.), *Managing Cyber Threats: Issues, Approaches and Challenges*. In: *Massive Computing*, vol. 5, Springer, Boston, MA, pp. 248–266.
- Kaplan, S., Garrick, B.J., 1981. On the quantitative definition of risk. *Risk Anal.* 1 (1), 11–27.
- Letier, E., Stefan, D., Barr, E.T., 2014. Uncertainty, risk, and information value in software requirements and architecture. In: *Proceedings of the 36th International Conference on Software Engineering. ICSE*, pp. 883–894, [Online]. Available: <https://www.academia.edu/download/53338530/2014-ICSE-Uncertainty.pdf>.
- Letier, E., Van Lamsweerde, A., 2025. Obstacle analysis in requirements engineering: Retrospective and emerging challenges. *IEEE Trans. Softw. Eng.* 51 (3), 795–801.
- Loomes, G., Sugden, R., 1982. Regret theory: An alternative theory of rational choice under uncertainty. *Econ. J.* 92 (368), 805–824.
- Madarie, R., Weulen Kranenbarg, M., de Poot, C., 2025. Examining the cyclical nature of crimes: A looped crime script of data theft from organizational networks. *Comput. Hum. Behav. Rep.* 17, 100548.
- Marchau, V.A.W.J., Walker, W.E., Bloemen, P.J.T.M., Popper, S.W., 2019. Decision making under deep uncertainty: From theory to practice. Springer Nature, Cham, Switzerland, [Online]. Available: <https://doi.org>, Open Access.
- Moore, M., Kazman, R., Klein, M., Asundi, J., 2003. Quantifying the value of architecture design decisions: Lessons from the field. In: *Proceedings of the 25th International Conference on Software Engineering. ICSE*, pp. 557–566, [Online]. Available: https://scholar.archive.org/work/3ulv2aumtrc3tnnjm5323sygbq/access/wayback/https://resources.sei.cmu.edu/asset_files/WhitePaper/2003_019_001_29571.pdf.
- Ou, X., Govindavajhala, S., Appel, A.W., 2005. MulVAL: A logic-based network security analyzer. In: *Proceedings of the 14th USENIX Security Symposium. USENIX Association*, Baltimore, MD, pp. 8–23.
- Ross, R., Winstead, M., McEvilly, M., 2022. Engineering trustworthy secure systems. (800-160v1r1), National Institute of Standards and Technology, Gaithersburg, MD, [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-160v1r1> Supersedes NIST SP 800-160 Vol. 1 (2016/2018).
- Shostack, A., 2014. *Threat Modeling: Designing for Security*. Wiley, Indianapolis, IN.
- UcedaVelez, T., Morana, M.M., 2015. Risk Centric Threat Modeling: Process for Attack Simulation and Threat Analysis. Wiley, Hoboken, NJ.
- Wang, L., Islam, T., Long, T., Singhal, A., Jajodia, S., 2008. An attack graph-based probabilistic security metric. In: *IFIP Annual Conference on Data and Applications Security and Privacy*. Springer, pp. 283–296.